

CORPORACIÓN UNIVERSITARIA MINUTO DE DIOS – UNIMINUTO

Especialización en Desarrollo de Software

Reporte de solución de problemas matemáticos

Evaluación de la calidad del software mediante métricas, verificación y auditoría

Caso: sistema MediCitas – IPS Salud Total

Yeyson Henao

Materia: Estándares y Métricas de Calidad en el Desarrollo de Software

Semana 2 — Aseguramiento de la calidad del software:

validación, verificación, revisiones y auditorías

Profesor: Cesar Alfonso Bolado Silva

Fecha de entrega: 10 de julio de 2026

1. Introducción

El presente reporte desarrolla, desde el rol de especialista en aseguramiento de la calidad del software (SQA), la evaluación del sistema MediCitas de la IPS Salud Total antes de la liberación de su versión 3.2, conforme al escenario y las evidencias provistas en el archivo de apoyo de la semana 2. El trabajo resuelve los problemas matemáticos derivados de las evidencias del caso, identifica y justifica hallazgos de seguridad con su impacto, define actividades de verificación y validación mediante la matriz provista, diligencia la lista de control de revisiones técnicas y el formato base de auditoría, aplica el estándar ISO/IEC 25010 y define métricas de calidad con fórmula y criterio de aceptación, para concluir con recomendaciones priorizadas sobre la liberación.

El enfoque parte de un principio central del aseguramiento de la calidad: la calidad se construye y se verifica a lo largo del proceso —mediante revisiones, mediciones y auditorías— y no se inspecciona únicamente al final (Chavarría, Oré y Pastor, 2016). Este principio resulta especialmente pertinente en el caso analizado, donde la presión comercial y una fecha contractual fija amenazan con subordinar las actividades de calidad al cronograma.

2. Análisis del escenario del caso

2.1 Síntesis del sistema y su contexto

MediCitas es el sistema de información de la IPS Salud Total, usado por una red de 12 clínicas ambulatorias en Bogotá y municipios cercanos. Soporta la gestión de citas, la historia clínica electrónica (HCE), órdenes y recetas, facturación electrónica integrada con la DIAN, recordatorios por SMS/WhatsApp y, en la versión 3.2 en preparación, dos cambios mayores: un módulo de telemedicina (videoconsulta) y un rediseño de la autenticación basado en SSO.

El contexto organizacional presenta factores de riesgo relevantes para la calidad: el equipo Scrum de 8 personas no cuenta con un área de aseguramiento de calidad independiente (solo 2 personas dedicadas parcialmente a pruebas); la fecha de liberación está fijada contractualmente a 3 semanas con alcance congelado; y existe presión comercial por lanzar telemedicina antes que la competencia. Esta combinación —equipo de pruebas reducido, hitos inamovibles y presión de mercado— es un patrón típico en el que los defectos escapan a producción por sacrificio de las actividades de V&V.

2.2 Actores involucrados

Actor	Relación con el sistema y con el riesgo de calidad
Pacientes	Acceden por aplicación móvil y portal web para agendar citas, consultar resultados y participar en teleconsultas; principales afectados por fallas de confidencialidad y disponibilidad.

Actor	Relación con el sistema y con el riesgo de calidad
Personal médico	Consulta y actualiza historias clínicas, emite órdenes y recetas y atiende teleconsultas; usuario objetivo del nuevo SSO y del 2FA (RF-014).
Personal administrativo	Gestiona agendamiento, atención al usuario y facturación; depende de la integración con la DIAN y del batch nocturno.
Administrador de TI / DBA	Administra infraestructura, bases de datos y accesos; involucrado directamente en INC-102 (cuenta compartida sin expiración de contraseñas).
Oficial de protección de datos	Responsable del cumplimiento de la normativa de datos personales y de historia clínica; interesado clave de los hallazgos HS-01, HS-04 y HS-05.
Equipo de desarrollo (Scrum)	Construye, prueba y despliega las funcionalidades; responsable del proceso de gestión de cambios (CR-201 a CR-205).
PayGateCol (pasarela de pagos)	Proveedor externo que procesa pagos de servicios particulares; sujeto al alcance de PCI-DSS (INC-104, RF-052).
API de WhatsApp Business	Proveedor externo de mensajería para recordatorios de citas; su cambio de proveedor fue el CR-204.

2.3 Funcionalidades críticas

- Autenticación y gestión de sesiones, incluido el nuevo esquema SSO (CR-201) y el 2FA del personal médico (RF-014).
- Agendamiento y cancelación de citas médicas, con requisito de desempeño de 2 s con 100 usuarios concurrentes (RF-031).
- Consulta y edición de historias clínicas electrónicas (HCE), con cifrado en reposo (RF-022) y log de auditoría inmutable (RF-045).
- Emisión de órdenes médicas y recetas electrónicas.
- Facturación electrónica con integración a la DIAN y proceso batch nocturno con el AS/400 (INC-106).
- Módulo de telemedicina (videoconsulta), en desarrollo, con cifrado de extremo a extremo requerido (RF-060).
- Notificaciones y recordatorios de citas por SMS/WhatsApp.
- Reportes gerenciales e indicadores clínicos.

2.4 Restricciones que condicionan la evaluación

- **Regulatorias:** Ley 1581 de 2012 y Decreto 1377 de 2013 (protección de datos personales); Resolución 1995 de 1999 (custodia y seguridad de la historia clínica); Resoluciones 2654 y 3100 de 2019 (telesalud y habilitación de telemedicina); estándar PCI-DSS para datos de tarjetas.
- **Técnicas:** Disponibilidad mínima del 99,5 % en horario de atención (7:00 a. m. a 9:00 p. m.); integración batch nocturna con el sistema legado AS/400; infraestructura híbrida (datos clínicos on-premise, telemedicina en AWS).

- **De gestión:** Fecha contractual fija con alcance congelado, lo que limita la maniobra a decisiones de calidad sobre lo ya construido: liberar, liberar parcialmente o aplazar.

2.5 Lectura crítica de las evidencias

Las evidencias del archivo de apoyo muestran un producto con brechas graves de seguridad y cumplimiento: de los seis requisitos del fragmento de especificación, ninguno se encuentra plenamente verificado y conforme (el 2FA quedó opcional, el cifrado en reposo y PCI-DSS están pendientes de verificación, el log de auditoría solo registra escrituras, el cifrado del canal de video está en desarrollo y la prueba de carga no se ejecutó). La bitácora registra cuatro incidencias de severidad alta, ninguna cerrada por completo. Dos de cinco cambios (CR-202 y CR-205) se desplegaron a producción sin revisión ni aprobación registrada. Finalmente, las pruebas de seguridad más críticas (pentesting de HCE, datos de tarjeta y carga de telemedicina) no fueron ejecutadas. Estas evidencias se cuantifican en la sección 3 y sustentan los hallazgos de la sección 4.

3. Solución de problemas matemáticos

Los siguientes problemas se plantean y resuelven sobre las evidencias del caso MediCitas (secciones 2.1 a 2.4 del archivo de apoyo). En cada uno se registra el procedimiento paso a paso, se selecciona la respuesta correcta entre las opciones y se interpreta el resultado frente al criterio de aceptación.

3.1 Problema 1. Porcentaje de cambios desplegados sin aprobación

La lista de control de cambios registra 5 cambios (CR-201 a CR-205). De ellos, CR-202 (configuración del servidor de video) y CR-205 (hotfix del batch de facturación) fueron desplegados sin revisión ni aprobación registrada. Calcule el porcentaje de cambios desplegados sin aprobación. El criterio del proceso de gestión de la configuración es 0 %.

Procedimiento:

1. Fórmula: $\% \text{ cambios sin aprobación} = (\text{Cambios desplegados sin aprobación} / \text{Total de cambios}) \times 100$.
2. Sustitución: $\% = (2 / 5) \times 100$.
3. Resultado: 40 %.

Opciones de respuesta:

- a) 20 %
- b) 40 % ✓ (respuesta correcta)**
- c) 50 %
- d) 60 %

Interpretación: dos de cada cinco cambios llegan a producción sin control. No es coincidencia que precisamente CR-202 esté ligado a la incidencia más grave del módulo de telemedicina (INC-

103, video sin cifrar): la ausencia de revisión de cambios es una causa raíz directa de defectos en producción.

3.2 Problema 2. Cobertura de ejecución del plan de pruebas

Los resultados preliminares registran 9 pruebas planificadas sobre los módulos del sistema, de las cuales 3 no fueron ejecutadas (pentesting de HCE, carga de telemedicina y seguridad de datos de tarjeta). Calcule la cobertura de ejecución del plan de pruebas. El criterio de aceptación es $\geq 95\%$.

Procedimiento:

1. Fórmula: Cobertura de ejecución = (Pruebas ejecutadas / Pruebas planificadas) $\times$ 100.
2. Sustitución: Cobertura = $((9 - 3) / 9) \times 100 = (6 / 9) \times 100$.
3. Resultado: 66,7 % (aproximado a una cifra decimal).

Opciones de respuesta:

- a) 77,8 %
- b) 88,9 %
- c) 66,7 % ✓ (respuesta correcta)**
- d) 72,0 %

Interpretación: un tercio del plan de pruebas no se ejecutó, y las tres pruebas omitidas son exactamente las de mayor riesgo (seguridad de datos clínicos, desempeño del módulo nuevo y cumplimiento PCI-DSS). La cobertura es insuficiente para sustentar una decisión de liberación.

3.3 Problema 3. Confiabilidad del proceso batch de facturación

El proceso batch nocturno de integración con el AS/400 se ejecuta una vez por noche y falló 3 veces en las últimas 4 semanas (28 ejecuciones) sin generar alerta (INC-106). Calcule la tasa de éxito del proceso. El criterio de aceptación para procesos críticos de facturación es $\geq 99\%$.

Procedimiento:

1. Fórmula: Tasa de éxito = $((\text{Ejecuciones totales} - \text{Fallos}) / \text{Ejecuciones totales}) \times 100$.
2. Sustitución: Tasa = $((28 - 3) / 28) \times 100 = (25 / 28) \times 100$.
3. Resultado: 89,3 % (aproximado a una cifra decimal).

Opciones de respuesta:

- a) 89,3 % ✓ (respuesta correcta)**
- b) 92,9 %
- c) 96,4 %
- d) 85,7 %

Interpretación: la tasa de éxito está casi 10 puntos por debajo del criterio y, más grave aún, los fallos no generan alertas automáticas, por lo que la detección depende de la revisión manual. Esto compromete la integridad de la facturación y la integración con la DIAN.

3.4 Problema 4. Tiempo máximo de indisponibilidad permitido por el acuerdo de servicio

El sistema exige una disponibilidad mínima del 99,5 % en el horario de atención (7:00 a. m. a 9:00 p. m., es decir, 14 horas diarias). Calcule el tiempo máximo de indisponibilidad permitido en un mes de 30 días, expresado en horas y minutos.

Procedimiento:

1. Cálculo de la ventana de servicio mensual: $14 \text{ horas/día} \times 30 \text{ días} = 420 \text{ horas}$.
2. Indisponibilidad máxima permitida: $(100 \% - 99,5 \%) = 0,5 \%$.
3. Sustitución: $420 \times 0,005 = 2,1 \text{ horas}$.
4. Conversión: $2,1 \text{ horas} \times 60 = 126 \text{ minutos}$ (2 horas y 6 minutos).

Opciones de respuesta:

- a) 4,2 horas (252 minutos)
- b) 2,1 horas (126 minutos) ✓ (respuesta correcta)**
- c) 1,5 horas (90 minutos)
- d) 3,0 horas (180 minutos)

Interpretación: el margen mensual de indisponibilidad es de apenas 2 horas y 6 minutos. Un solo incidente como los fallos no alertados del batch, o una caída del módulo de telemedicina sin pruebas de carga, puede consumir el presupuesto de indisponibilidad completo e incumplir el acuerdo de servicio.

3.5 Problema 5. Requisitos de prioridad alta con verificación completa

El fragmento de especificación contiene 5 requisitos de prioridad alta (RF-014, RF-022, RF-045, RF-052 y RF-060). Según su estado actual (implementado como opcional, pendiente de verificación, solo registra escrituras, pendiente de verificación y en desarrollo, respectivamente), calcule el porcentaje de requisitos de prioridad alta plenamente verificados y conformes. El criterio de liberación exige el 100 %.

Procedimiento:

1. Identificación: ninguno de los 5 requisitos de prioridad alta se encuentra verificado y conforme con lo especificado.
2. Fórmula: $\% \text{ conformes} = (\text{Requisitos verificados conformes} / \text{Requisitos de prioridad alta}) \times 100$.
3. Sustitución: $\% = (0 / 5) \times 100$.
4. Resultado: 0 %.

Opciones de respuesta:

- a) 20 %
- b) 40 %
- c) 10 %

d) 0 % ✓ (respuesta correcta)

Interpretación: el resultado más crítico del análisis. Ningún requisito de seguridad o cumplimiento de prioridad alta está en condición de conformidad verificada; la brecha entre lo especificado y lo verificado es total en el frente que concentra el riesgo regulatorio del sistema.

3.6 Síntesis de resultados

Indicador	Resultado	Criterio de aceptación	¿Cumple?
P1. Cambios desplegados sin aprobación	40 %	0 %	No
P2. Cobertura de ejecución del plan de pruebas	66,7 %	≥ 95 %	No
P3. Tasa de éxito del batch de facturación	89,3 %	≥ 99 %	No
P4. Margen mensual de indisponibilidad	2,1 h (126 min)	Referencia del SLA (99,5 %)	Referencia
P5. Requisitos de prioridad alta conformes	0 %	100 %	No

Todos los indicadores evaluables incumplen su criterio de aceptación. Esta evidencia cuantitativa, junto con los hallazgos de seguridad de la siguiente sección, fundamenta la conclusión del reporte.

4. Identificación y justificación de hallazgos de seguridad

Del cruce entre requisitos, bitácora de incidencias, control de cambios y resultados de pruebas se identifican y justifican los siguientes seis hallazgos de seguridad con su impacto:

ID	Hallazgo y justificación	Evidencia	Criterio incumplido	Impacto	Característica ISO/IEC 25010 comprometida
HS-01	Control de acceso deficiente en la HCE: un médico accedió a historias de pacientes no asignados manipulando el identificador en la URL (referencia insegura directa a objetos, IDOR); además, el control de acceso por rol no se probó en todos los escenarios.	INC-101; pruebas HCE «aprobado con observaciones»	Res. 1995/1999; Ley 1581/2012	Violación de la confidencialidad de datos de salud y de la reserva de la historia clínica; exposición a sanciones de la SIC y del ente de salud; pérdida de confianza de pacientes.	Seguridad — confidencialidad (acceso a datos restringido solo a autorizados).

ID	Hallazgo y justificación	Evidencia	Criterio incumplido	Impacto	Característica ISO/IEC 25010 comprometida
HS-02	Gestión de identidades insegura en administración/TI: cuenta «admin_ti» compartida por 4 personas y contraseñas administrativas sin expiración; el 2FA quedó implementado como opcional pese a ser requisito de prioridad alta.	INC-102; RF-014	RF-014; buenas prácticas de control de acceso	Imposibilidad de atribuir acciones a individuos (sin rendición de cuentas); una sola credencial comprometida otorga control administrativo total y persistente del sistema.	Seguridad — autenticidad y responsabilidad (identidad verificable y acciones atribuibles).
HS-03	Canal de telemedicina sin cifrar: la videoconsulta quedó transmitiendo sobre HTTP porque una configuración de pruebas pasó a producción sin revisión (CR-202); el cifrado de extremo a extremo (RF-060) sigue en desarrollo y la prueba de cifrado falló.	INC-103; CR-202; prueba de seguridad «fallida»	RF-060; Res. 2654/2019	Interceptación de consultas médicas en tránsito (datos sensibles de salud); incumplimiento de las condiciones de habilitación de telemedicina; riesgo reputacional y legal en el lanzamiento estrella de la IPS.	Seguridad — confidencialidad e integridad de los datos en tránsito.
HS-04	Datos de tarjeta expuestos en logs: la pasarela de pagos registra el número completo de tarjeta sin enmascarar y la auditoría de cumplimiento PCI-DSS está pendiente.	INC-104; RF-052; prueba de seguridad de pagos no ejecutada	PCI-DSS; RF-052	Incumplimiento directo de PCI-DSS con riesgo de multas, pérdida de la capacidad de procesar pagos y fraude financiero a pacientes en caso de fuga de los logs.	Seguridad — confidencialidad; compatibilidad normativa del tratamiento de datos financieros.
HS-05	Trazabilidad de auditoría incompleta: el sistema solo registra escrituras sobre la HCE; las consultas (lecturas) no quedan en el log, que además debe ser inmutable según especificación.	INC-105; RF-045	RF-045; Res. 1995/1999	Los accesos indebidos de solo lectura (como el de INC-101) resultan indetectables e inauditables; debilita la posición probatoria de la IPS ante el regulador y ante reclamos de pacientes.	Seguridad — responsabilidad / no repudio (trazabilidad completa de las acciones).
HS-06	Proceso de cambios y monitoreo débiles: dos cambios en producción sin aprobación (CR-202, CR-205) y fallos recurrentes del batch de	CR-202; CR-205; INC-106	Proceso de gestión de cambios; criterio de operación de procesos críticos	Regresiones no evaluadas en producción; errores de facturación e integración DIAN silenciosos que	Fiabilidad — madurez y capacidad de recuperación; mantenibilidad — modificabilidad.

ID	Hallazgo y justificación	Evidencia	Criterio incumplido	Impacto	Característica ISO/IEC 25010 comprometida
	facturación sin alertas automáticas.			pueden acumular impacto financiero y tributario antes de ser detectados.	

Los hallazgos HS-01 a HS-04 se clasifican de severidad alta, por afectar directamente la confidencialidad de datos clínicos y financieros y el cumplimiento regulatorio; HS-05 y HS-06 de severidad media-alta, por debilitar los controles de detección, trazabilidad y gestión de la configuración que soportan a los demás.

5. Actividades de verificación y validación

5.1 Diferenciación conceptual

La verificación responde a la pregunta «¿se construyó correctamente?»: comprueba, mediante técnicas predominantemente estáticas (revisiones de código, inspecciones, análisis de configuración, revisión documental), que los productos de trabajo cumplen su especificación y los estándares definidos. La validación responde a «¿se construyó lo que el usuario necesita?»: comprueba mediante pruebas dinámicas orientadas al usuario y a su contexto real (pruebas de aceptación, usabilidad, pilotos) que el sistema satisface las necesidades y el uso previsto. Son complementarias: la verificación detecta temprano los defectos de construcción y la validación confirma la idoneidad del producto; la debilidad simultánea de ambas, como ocurre en MediCitas, es lo que permite que defectos como INC-103 lleguen a producción (Chavarría et al., 2016).

5.2 Matriz de verificación y validación diligenciada

Se diligencia la matriz provista en el archivo de apoyo (sección 3), cubriendo los requisitos y funcionalidades críticas del escenario:

ID	Requisito / funcionalidad	Tipo (V/V)	Técnica a aplicar	Responsable	Criterio de aceptación	Evidencia esperada
1	RF-014 — Autenticación 2FA	Verificación	Revisión de código e inspección de configuración	Líder técnico	2FA disponible y exigible (no opcional) para roles críticos	Acta de revisión; configuración exportada
2	RF-014 / SSO — Flujo de acceso del personal	Validación	Prueba de aceptación de usuario (UAT) con personal médico y administrativo	Analista de pruebas + usuarios clave	100 % de los flujos de acceso críticos aprobados por los usuarios	Casos UAT ejecutados y firmados

ID	Requisito / funcionalidad	Tipo (V/V)	Técnica a aplicar	Responsable	Criterio de aceptación	Evidencia esperada
3	RF-022 — Cifrado en reposo de la HCE (AES-256)	Verificación	Inspección de configuración de base de datos y revisión de la librería de cifrado (CR-203)	DBA + líder técnico	Cifrado AES-256 activo y verificado en todos los repositorios de HCE	Informe de inspección; evidencia de configuración
4	RF-031 — Desempeño del agendamiento (≤ 2 s con 100 usuarios)	Validación	Prueba de carga en ambiente equivalente a producción (INC-107 pendiente)	Analista de pruebas	Tiempo de respuesta ≤ 2 s en el percentil 95 con 100 usuarios concurrentes	Reporte de la herramienta de pruebas de carga
5	RF-045 — Log de auditoría inmutable de accesos a la HCE	Verificación	Revisión técnica del mecanismo de logging e inspección de registros	Líder técnico + oficial de protección de datos	Registro del 100 % de lecturas y escrituras; log protegido contra alteración	Acta de revisión; extractos del log
6	Control de acceso por rol a la HCE (INC-101)	Validación	Pruebas de seguridad dinámicas (DAST) y pentesting con casos de acceso indebido	Especialista en seguridad	0 accesos no autorizados posibles entre pacientes no asignados	Informe de pentesting con retest
7	RF-052 — Cumplimiento PCI-DSS en pagos	Verificación	Auditoría de cumplimiento y revisión de logs de la pasarela (INC-104)	Auditor externo + oficial de protección de datos	Ningún PAN completo en logs; controles PCI-DSS aplicables verificados	Informe de auditoría PCI-DSS
8	RF-060 — Cifrado de extremo a extremo en telemedicina	Verificación	Revisión de arquitectura y de configuración del servidor de video (CR-202)	Líder técnico + especialista en seguridad	Canal de video 100 % cifrado (TLS/SRTP) en producción	Acta de revisión; captura de configuración
9	Telemedicina — Videoconsulta funcional	Validación	UAT y piloto controlado con médicos y pacientes en una sede	Product Owner + usuarios piloto	Consultas completadas satisfactoriamente; usabilidad aceptada por médicos y pacientes	Actas de piloto; encuestas de satisfacción
10	Batch de facturación AS/400 (INC-106)	Verificación	Revisión técnica del job nocturno y de su mecanismo de alertamiento	Dev responsable + operaciones	Alertas automáticas ante fallo; tasa de éxito ≥ 99 % en 4 semanas	Bitácora de ejecuciones; evidencia de alertas

6. Lista de control de revisiones técnicas diligenciada

Se diligencia la lista de control provista en el archivo de apoyo (sección 4), aplicada al estado actual de MediCitas v3.2 según las evidencias. Todo «No» queda vinculado a un hallazgo o incidencia y debe generar acción correctiva antes de la liberación:

N°	Ítem de revisión	Cumple	Observaciones / evidencia
1	El código fuente cumple con los estándares de codificación definidos por el equipo.	N.A.	No hay evidencia disponible en el archivo de apoyo; verificar en revisión de código.
2	Existe trazabilidad entre los requisitos y los casos de prueba.	No	3 requisitos de prioridad alta sin prueba asociada ejecutada (RF-022, RF-031, RF-052).
3	Todos los cambios fueron documentados y aprobados antes de su despliegue a producción.	No	CR-202 y CR-205 desplegados sin revisión ni aprobación registrada (40 % del total).
4	Los mecanismos de autenticación y autorización protegen adecuadamente los recursos críticos.	No	INC-101 (IDOR en HCE); INC-102 (cuenta compartida, contraseñas sin expiración); 2FA opcional (RF-014).
5	La información sensible (datos clínicos, financieros) se almacena y transmite cifrada.	No	RF-022 pendiente de verificación; INC-103 (video sobre HTTP); INC-104 (PAN sin enmascarar en logs).
6	Existen registros de auditoría (logs) para accesos y modificaciones a información crítica.	No	INC-105 / RF-045: solo se registran escrituras; las lecturas de la HCE no quedan en el log.
7	Se ejecutaron pruebas de seguridad (pentesting) antes de la liberación.	No	Pentesting de HCE no ejecutado «por falta de tiempo»; prueba de cifrado de telemedicina fallida.
8	Se ejecutaron pruebas de carga/rendimiento sobre los módulos críticos.	No	INC-107: prueba de carga de agendamiento no ejecutada; sin ambiente de carga para telemedicina (RF-031 sin probar).
9	El manejo de datos personales cumple con la Ley 1581 de 2012 y su reglamentación.	No	Accesos indebidos a datos sensibles (INC-101) y exposición de datos financieros (INC-104) sin cierre.
10	El manejo de la historia clínica cumple con la Resolución 1995 de 1999.	No	Custodia y trazabilidad incompletas: INC-101 e INC-105 abiertos.
11	El módulo de telemedicina cumple con las disposiciones de la Resolución 2654 de 2019.	No	Canal sin cifrar (INC-103, RF-060 en desarrollo); condiciones de habilitación no verificadas.
12	Existen alertas automáticas ante fallos de procesos críticos (p. ej., el batch de facturación).	No	INC-106: 3 fallos del batch en 4 semanas sin alerta automática.
13	La documentación técnica y de usuario está actualizada para la versión a liberar.	N.A.	Sin evidencia en el archivo de apoyo; incluir en la revisión previa a liberación.
14	Los riesgos técnicos y regulatorios identificados fueron mitigados antes de la liberación.	No	4 incidencias de severidad alta abiertas o con cierre parcial; 0 % de requisitos de prioridad alta conformes.

Resultado de la revisión: 12 de los 14 ítems evaluables se encuentran en incumplimiento y 2 no cuentan con evidencia disponible. Ningún ítem del checklist puede marcarse «Sí» con las evidencias actuales, lo que por sí solo impide recomendar la liberación.

7. Formato base de auditoría diligenciado

7.1 Datos generales

Campo	Contenido
Objetivo de la auditoría	Evaluar de forma independiente si MediCitas v3.2 y su proceso de desarrollo cumplen los requisitos de seguridad y trazabilidad especificados, los criterios de calidad definidos y la normativa aplicable a datos personales, historia clínica, telemedicina y pagos, antes de autorizar la liberación a producción.
Alcance	Módulos de autenticación/SSO, historia clínica electrónica, telemedicina, pagos y facturación (incluida la integración batch con AS/400) de la versión 3.2; procesos de gestión de cambios y de pruebas del ciclo de la versión. Se excluyen los módulos de notificaciones y reportes, sin hallazgos asociados.
Criterios de auditoría	ISO/IEC 25010 (seguridad, fiabilidad, adecuación funcional); Ley 1581 de 2012 y Decreto 1377 de 2013; Resolución 1995 de 1999; Resoluciones 2654 y 3100 de 2019; PCI-DSS; requisitos RF-014, RF-022, RF-031, RF-045, RF-052 y RF-060; procedimiento interno de control de cambios.
Equipo auditor	Auditor líder independiente del equipo de desarrollo (especialista SQA), un especialista en seguridad de la información y el oficial de protección de datos como observador. Auditado principal: líder técnico del proyecto.
Fecha de ejecución	Semana previa a la fecha contractual de liberación (5 días hábiles), con reunión de apertura el día 1 y reunión de cierre con plan de acción el día 5.
Evidencias a recolectar	Bitácora de incidencias (INC-101 a INC-107) y estados de cierre; lista de control de cambios (CR-201 a CR-205) y aprobaciones; resultados y registros de ejecución de pruebas; extractos del log de auditoría de la HCE; logs de la pasarela de pagos; configuración del servidor de video y del cifrado en reposo; matriz V&V y checklist de revisión diligenciados.

7.2 Hallazgos de auditoría

N°	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
1	Acceso no autorizado a historias clínicas mediante manipulación de URL y control por rol sin probar en todos los escenarios.	Res. 1995/1999; Ley 1581/2012; RF-045	INC-101; resultados de pruebas de HCE	Alta	Corregir el control de acceso (verificación de autorización por recurso), ejecutar pentesting con retest y cerrar INC-101 antes de liberar.

N°	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
2	Canal de videoconsulta sin cifrar en producción por cambio no aprobado (configuración de pruebas desplegada).	Res. 2654/2019; RF-060; proceso de cambios	INC-103; CR-202; prueba de cifrado fallida	Alta	Bloquear la liberación de telemedicina hasta verificar cifrado extremo a extremo y regularizar CR-202.
3	Números completos de tarjeta registrados en logs de la pasarela de pagos; auditoría PCI-DSS pendiente.	PCI-DSS; RF-052	INC-104; prueba de seguridad de pagos no ejecutada	Alta	Enmascarar/tokenizar el PAN de inmediato, depurar logs históricos y ejecutar la auditoría de cumplimiento PCI-DSS.
4	Cuenta administrativa compartida sin expiración de contraseñas y 2FA opcional para personal médico.	RF-014; buenas prácticas de gestión de identidades	INC-102; RF-014	Alta	Cuentas nominales individuales, expiración y robustez de contraseñas, y 2FA obligatorio para roles críticos.
5	Trazabilidad incompleta (lecturas de HCE sin registro) y fallos del batch de facturación sin alertas automáticas.	RF-045; criterios de operación de procesos críticos	INC-105; INC-106	Media-Alta	Completar el log de auditoría (lecturas y escrituras, inmutable) e implementar alertamiento automático del batch con monitoreo.

7.3 Conclusión general de la auditoría

El sistema MediCitas v3.2 presenta no conformidades mayores frente a los criterios regulatorios (Ley 1581, Resolución 1995, Resolución 2654, PCI-DSS) y frente a sus propios requisitos de seguridad de prioridad alta, ninguno de los cuales se encuentra verificado y conforme (0 %). El proceso de gestión de cambios evidencia despliegues sin aprobación (40 %) y el plan de pruebas se ejecutó parcialmente (66,7 %), omitiendo precisamente las pruebas de mayor riesgo. En consecuencia, la auditoría no recomienda la liberación de la versión 3.2 en las condiciones actuales; se propone una liberación por fases condicionada al cierre verificado de los hallazgos 1 a 4 (bloqueantes) y del hallazgo 5.

7.4 Firma

Auditor	Fecha
Yeyson Henao — Especialista en aseguramiento de la calidad del software	10 de julio de 2026

8. Estándar de referencia y métricas de calidad

8.1 Selección y aplicación del estándar ISO/IEC 25010

Se selecciona ISO/IEC 25010 (modelo de calidad del producto, familia SQuaRE) como estándar de referencia, por tres razones: (1) proporciona características y subcaracterísticas medibles que permiten trazar cada hallazgo y cada métrica a un atributo de calidad; (2) es el estándar sugerido en el propio formato de auditoría del caso; y (3) frente a modelos orientados al proceso como CMMI, TSP o PSP —adecuados para la mejora organizacional a mediano plazo (Chavarría et al., 2016)—, la decisión inmediata que exige el caso es sobre el producto. La selección del modelo conforme al tamaño, la madurez y el objetivo de la organización sigue además la guía de Paredes, Benavides y Sánchez (2017): para una IPS sin área de calidad consolidada, un modelo de producto con métricas simples es el punto de partida realista.

Aplicación al caso: las características priorizadas son seguridad (confidencialidad: HS-01, HS-03, HS-04; responsabilidad/trazabilidad: HS-02, HS-05; autenticidad: RF-014), fiabilidad (madurez y disponibilidad: INC-106, SLA del 99,5 %), adecuación funcional (completitud funcional: cobertura del plan de pruebas) y eficiencia de desempeño (capacidad: RF-031 sin probar). Cada métrica de la sección 8.2 se alinea con una de estas características.

8.2 Definición de métricas

Métrica	Fórmula / forma de medición	Valor actual	Criterio de aceptación	Característica ISO/IEC 25010
M1. Cobertura de ejecución del plan de pruebas	(Pruebas ejecutadas / pruebas planificadas) × 100	66,7 %	≥ 95 % antes de liberar	Adecuación funcional (completitud)
M2. Cambios desplegados con aprobación	(Cambios aprobados antes del despliegue / total de cambios desplegados) × 100	60 %	100 %	Mantenibilidad (modificabilidad) / calidad del proceso
M3. Tasa de éxito del batch de facturación	((Ejecuciones – fallos) / ejecuciones) × 100, ventana móvil de 4 semanas	89,3 %	≥ 99 % con alertamiento automático	Fiabilidad (madurez)
M4. Disponibilidad en horario de atención	(Tiempo de servicio – indisponibilidad) / tiempo de servicio × 100 (ventana 7:00–21:00)	Por medir (SLA nuevo)	≥ 99,5 % (indisponibilidad ≤ 126 min/mes)	Fiabilidad (disponibilidad)
M5. Requisitos de prioridad alta verificados conformes	(Requisitos alta prioridad conformes verificados / total alta prioridad) × 100	0 %	100 % antes de liberar	Seguridad / adecuación funcional (corrección)
M6. Incidencias de severidad alta abiertas	Conteo de incidencias de severidad alta sin cierre total verificado	4 (INC-101 a INC-104)	0 antes de liberar (quality gate)	Seguridad (confidencialidad, integridad)
M7. Cobertura de trazabilidad de accesos a la HCE	(Tipos de acceso registrados en el log / tipos de acceso)	50 % (solo escrituras)	100 %, con log inmutable	Seguridad (responsabilidad /

Métrica	Fórmula / forma de medición	Valor actual	Criterio de aceptación	Característica ISO/IEC 25010
	definidos: lectura y escritura) × 100			rendición de cuentas)

Las métricas M1 a M4 se recalculan tras cada ciclo de corrección y prueba. M5, M6 y M7 constituyen condiciones de salida obligatorias (quality gates): su incumplimiento bloquea la liberación con independencia del estado de las demás.

9. Conclusiones y recomendaciones priorizadas

La evidencia cuantitativa (0 % de requisitos críticos conformes, 66,7 % de cobertura de pruebas, 40 % de cambios sin aprobación, 89,3 % de éxito del batch) y cualitativa (cuatro hallazgos de severidad alta abiertos, con impacto regulatorio en Ley 1581, Resolución 1995, Resolución 2654 y PCI-DSS) conduce a una conclusión inequívoca: MediCitas v3.2 no está en condiciones de liberarse a producción en la fecha contractual con su alcance completo. Dado que el alcance está congelado y la fecha es fija, la alternativa técnica responsable es una liberación por fases que excluya los componentes de mayor riesgo hasta su cierre verificado. Se recomienda el siguiente plan priorizado:

1. **Prioridad 1:** Contener las exposiciones activas de datos: enmascarar el número de tarjeta en los logs de pagos (HS-04) y suspender el uso del canal de video no cifrado (HS-03). Son correcciones acotadas, de impacto regulatorio inmediato y bloqueantes para cualquier liberación.
2. **Prioridad 2:** Corregir y verificar el control de acceso a la HCE (HS-01) con pentesting y retest, y regularizar la gestión de identidades: cuentas nominales, expiración de contraseñas y 2FA obligatorio para roles críticos (HS-02).
3. **Prioridad 3:** Aplazar el lanzamiento del módulo de telemedicina hasta verificar el cifrado de extremo a extremo (RF-060), ejecutar sus pruebas de carga y validar las condiciones de habilitación de la Resolución 2654 de 2019. Liberar en la fecha contractual únicamente el resto del sistema, si cierra las prioridades 1 y 2.
4. **Prioridad 4:** Completar el log de auditoría de la HCE (lecturas y escrituras, inmutable, RF-045) e implementar alertamiento automático del batch de facturación con monitoreo de su tasa de éxito (M3).
5. **Prioridad 5:** Institucionalizar el proceso de calidad: aprobación obligatoria de cambios antes del despliegue (M2 = 100 %), quality gates basados en las métricas M5 a M7, y a mediano plazo la consolidación de un área de SQA con prácticas de mejora de proceso del tipo TSP/PSP (Chavarría et al., 2016), seleccionando el modelo según la guía de Paredes et al. (2017).

El caso ilustra la lección central de la semana: cuando la verificación (revisiones, inspecciones, control de cambios) y la validación (pruebas orientadas al usuario y al riesgo) se subordinan al cronograma, los defectos no desaparecen: se trasladan a producción con intereses. Las métricas convierten esa realidad en criterios objetivos de decisión, y las revisiones y auditorías aportan la disciplina para que la decisión de liberar sea un acto técnico y no solo comercial.

Referencias

- Bolado Silva, C. A. (2026). Archivo de apoyo. Actividad semana 2 — Reporte de solución de problemas matemáticos: evaluación de la calidad del software mediante métricas, verificación y auditoría [Material del curso Estándares y Métricas de Calidad en el Desarrollo de Software]. Corporación Universitaria Minuto de Dios – UNIMINUTO.
- Chavarría, A., Oré, S. y Pastor, C. (2016). Aseguramiento de la calidad en el proceso de desarrollo de software utilizando CMMI, TSP y PSP. *Revista Ibérica de Sistemas e Tecnologías de Informação*, (20), 62–77. <https://doi.org/10.17013/risti.20.62-77>
- International Organization for Standardization. (2011). ISO/IEC 25010:2011. Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — System and software quality models. ISO.
- Ministerio de Salud y Protección Social. (1999). Resolución 1995 de 1999, por la cual se establecen normas para el manejo de la historia clínica. República de Colombia.
- Ministerio de Salud y Protección Social. (2019). Resolución 2654 de 2019, por la cual se establecen disposiciones para la telesalud y parámetros para la práctica de la telemedicina en el país. República de Colombia.
- Paredes, L., Benavides, L. y Sánchez, N. (2017). Guía de recomendación para la selección de un modelo de calidad para la mejora de procesos de software (SPI). *Revista Ciencias Estratégicas*, 25(38), 495–510.
- PCI Security Standards Council. (2022). Payment Card Industry Data Security Standard (PCI-DSS) v4.0. PCI SSC.
- Urrea-Contreras, S., Flores-Rios, B., Astorga-Vargas, M., Ibarra-Esquer, J., González-Navarro, F. F., Velazquez-Solis, P., Albarracín, C. y Ardila, A. (2020). Propuesta de un marco de trabajo para la identificación y selección de algoritmos y herramientas de minería de procesos orientado a las organizaciones de desarrollo de software. *Revista Ibérica de Sistemas e Tecnologías de Informação*, (25), 348–363.